Threat evolution Q3 2016

GROUP IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3

Executive Summary: Threats to the Financial Sector, Global 4

Executive Summary: Threats to Financial Sector in Russia 6

Executive Summary: Threats to the Government sector 7

Forecasts for Q4 2016 8

Threats to the Financial Sector, Global 9

Targeted attacks 9

Banking threats for PC and Android 9

Attacks on ATM and POS terminals 19

Phishing attacks 20

DDoS attacks 20

Data leakage 20

Threats to the Financial Sector in Russia 21

Targeted attacks 21

Banking Trojans for PC and Android 21

Attacks on ATMs 25

Data leakage 25

Threats to the Government sector 26

APT 26

Hacktivism 27

Data leakage 29

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on the USA, Europe, Russia and Australia. This document also provides a comprehensive description of threats to governments, including hacktivists' attacks, targeted attacks supported by government and significant data leaks.

Researchers have observed that malware used to target victims in Russia is often then 'exported' to other countries, that is why we believe it is essential to inform our international clients about Russian threats along with those targeting them directly.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring the most secretive underground hacker forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive Summary: Threats to the Financial Sector, Global

Targeted attacks

- During the reporting period, Group-IB specialists detected targeted attacks on banks all over the world. The Cobalt criminal group employed Cobalt Strike software to attack banks in the UK, the Netherlands, Romania, Belorussia, Poland, Spain, Estonia, Bulgaria, Armenia, Kyrgyzstan, Malaysia, Moldova, Georgia, Ukraine, Thailand and China. Russian hackers are believed to have been behind these attacks.
- Also, researchers have continued recording attacks targeting the SWIFT payment system. Over the last period, major thefts were performed on banks in Ukraine (June, about 10 mln. USD) and Thailand (August, around $350,000 USD). According to results of Group-IB's analysis, attacks on the international interbank messaging system were conducted by the same criminal group that was detected to use Cobalt Strike. Hackers apply their own malware that is able to monitor transactions performed through SWIFT. Group-IB specialists are continuing investigations on these incidents.

Banking threats to PC and Android

Trojans for Android were used to steal money from the accounts of individuals, while PC Trojans were used both for attacks on individuals and companies. All malicious programs targeting clients of foreign banks, which are outlined in this report section, are not used on the territory of CIS countries.

Trojans for Android:

- Marcher is used by at least 3 criminal groups to attack banks in Europe and Australia. Group-IB specialists classified known groups as Rahunok, Alien, and MMS-service.
- Instant VBV Grabber, a Trojan for Android, was used to attack banks in Northern Europe
- GM Bot Trojan was used only in attacks against Australian banks

Trojans for PC

- During the reporting period Group-IB specialists detected attacks on banks in Europe, the US and Australia using the following banking Trojans: Qadars, Vawtrak, Dridex, Atmos, ISFB (Gozi), Zeus, KINS, Tinba, Qbot, Gootkit, Kronos.
- Specialists detected a new malicious program Trickbot that has a similar functionality to the Dyre (Dyreza) banking Trojan and is believed to be linked to the team behind Dyre. Trickbot employs malicious Dyre SSL certificates.
- New Trojans named Gnaeus and Lider_soft as well as a module for web injection and form grabbing (an unnamed malware at this point) were detected to be available for purchase on underground forums. These programs are designed to attack Windows OS and described in detail in the following reports: CP-1432, CP-1436, CP-1452. They are sold on a Russian-speaking forum, where performing attacks in Russia is forbidden, that's why these malicious programs are believed to be threatening Europe and North America.
- According to our information, activity of the banking Trojan dubbed "Panda Banker" decreased compared to the previous quarter.
- The Microsoft Word Intruder (MWI) exploit kit that is available on deep web hacking forums, was modified – developers added an exploit leveraging a vulnerability in Microsoft Office that was

discovered in 2016. MWI now allows the operators to execute arbitrary code on the victim's system.

Attacks on ATM and POS terminals

A new APT attack using Cobalt Strike software, which was previously mentioned in this report, is aimed at stealing money from ATMs.

Phishing attacks

Group-IB detected fraud schemes involving phishing and vishing.

A phishing attack was performed against Expedia in order to steal bank card data.

In the case of vishing, criminals sent fake SMS messages acting as banks asking victims to call a specific number. When the victim called back, he/she was prompted by an automated machine (similar to those used in real banks) to provide their bank card data using the keypad on their phone.

DDoS attacks

Powerful DDoS attacks were performed using a new botnet type involving IoT devices (IoT - Internet of Things). This botnet was developed based on the Mirai DDoS Trojan. This Trojan's source code has been released online.

Data leaks

- Data and hacking tools that purportedly belonged to the Equation APT group were released. The leaked archive is claimed to contain a number of 0day exploits. A portion of the leaked data is published on open resources and has been analyzed by security specialists and hackers. Other "best" files will be auctioned off to the highest bidder. 0day exploits are known to be dangerous to all industries, including finance, manufacturers, and governments.
- A database containing the financial information of 324,380 BlueSnap users was published online. Clients of banks worldwide were affected.

Executive Summary: Threats to Financial Sector in Russia

Targeted attacks

Hackers conduct targeted attacks on banks in order to steal money or get access to payment systems, POS terminals and ATMs. In Q3 2016 activity of 2 criminal groups performing attacks in Russia was recorded:

- A new criminal group attacking banks using Cobalt Strike software in order to access ATM control systems and SWIFT;
- A targeted attack using a new malware dubbed Ostin to spy on large Russian enterprises.

Banking Trojans for PC and Android

During the reporting period Group-IB specialists detected attacks on Russian banks using specific Trojans. The vast majority of Trojans for PC were used to deplete accounts of businesses, while mobile Trojans were used to steal money from accounts of individuals. In Q3 2016 Group-IB specialists observed activity of the following banking Trojans:

- Trojans for PC: ProxyAdder, RTM, Jupiter (aka Bolek), Buhtrap, Ranbyus.
  It is worth reiterating that in June 2016 a message on search for partners to distribute the Jupiter Trojan was published on an underground forum, which caused an increase in its attacks on Russian banks.
  A new version of the Ranbyus was recently discovered. Its config file contains a code to perform automatic manipulations in the 1C:Enterprise system, which expands the list of its potential targets.
- Mobile Trojans: Tiny.z, Agent.sx, Cron, Honli, Opfake, FakeInst.fb.
  In addition to the above-mentioned malware, Russian banks suffered attacks using a new Android Trojan dubbed Gugi (Limebot).
  Group-IB researchers did not detect attacks of infamous Trojans such as FakeInst.ft, Agent.BID, GM Bot against Russian banks.

Attacks on ATMs

A new APT attack using Cobalt Strike software, which was previously mentioned in this report, is aimed at stealing money from ATMs.

Data leakage

- During the reporting period Group-IB specialists detected activity from several groups of malicious insiders. They continued creating services designed to sell confidential bank data and promoted them on underground platforms.
- Roughly 324,000 financial records were stolen from the payment processor BlueSnap and were published online. The data dump contains information about Russian and foreign banks.
- Information from millions of Rambler.ru email accounts was leaked online.

Executive Summary: Threats to the Government sector

Targeted attacks

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructures. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q3 2016 the following active campaigns were detected:

- An attack on the World Anti-Doping Agency (WADA) database performed by the Fancy Bears (APT28) group;
- APT Buckeye;
- APT Patchwork;
- APT ProjectSauron

Hacktivism

In Q3 2016, hacktivists conducted over 2400 attacks on more than 3300 various online resources. Over 2500 attacks detected were of the “page replacement” type (Defacement) and 937 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Israel, the USA, Turkey, Russia, Peru, the UK, India, Germany, Brazil and Venezuela. The most active gangs which are believed to have concentrated their attacks on one country were AnonymousCenter (attacks on Brazilian websites); AleviHackers (attacks on Turkish resources); Anonymous Nigeria (attacks on websites of Nigeria); AnonIron, Leonidus2015 (attacks on the US resources); Anonymous Red Cult (attacks on Israeli websites).

Data leakage

During the reporting period, analysts detected the following leaks of government databases:

- Donald Trump’s presidential campaign website was hacked. Email exchanges of Trump’s campaign team members were stolen.
- Hackers published a data array containing email messages of Andrey Purgin, a Ukrainian activist, co-founder of the self-proclaimed Donetsk People's Republic (DPR). The archive includes DPR’s internal documentation, bank payment orders, administrative notes, etc.
- An unknown group named Shadow Brokers breached databases of Equation Group, which was involved in attacks on governments and enterprises. The data that is published online and being auctioned includes a variety of tools leveraging unpatched security flaws and 0day exploits. They can be used by hackers to perform sophisticated attacks.

Forecasts for Q4 2016

Based on the threats detected, we can forecast the following future incidents in Europe, the USA, and Australia:

1) The Cobalt criminal group using Cobalt Strike software will continue actively attacking banks in Europe, Asia, and probably will start targeting North America. Their key target is ATM networks;
2) Cobalt to return to attacks against SWIFT on banks worldwide. The main motivation of such renewal is the ability to steal much more money than their recent attacks on ATMs.
3) The Trickbot banking Trojan is still being tested. It is expected to be actively distributed. As it is similar to the source code of Dyre, which is widely considered to be one of the world's most dangerous and powerful banking Trojans, Trickbot can become the No. 1 threat to security in Q4 2016.
4) Because of the Mirai bot source code published online, Group-IB specialists expect an increase in the number of groups using this tool and the average power of attacks. Internet of Things devices will be primarily used as bots for DDoS attacks.
5) The amount of attacks using such banking Trojans as Qadars, Gootkit, Tinba, Zeus, KINS, Vawtrak, Gozi, Atmos will continue at the same level.
6) Marcher with its modifications is expected to be the most dangerous Android Trojan. Exo and Alien-bot Trojan developed based on the Marcher source code were supported by new web injects for mobile browsers, which will enable hackers to perform new fraud schemes of automated payment manipulations and data substitution on mobile devices.
7) Criminals will start using Android Trojans to steal from companies. The main infection vector will be spear phishing mailouts and malicious advertising in search engine page results.

Based on the threats detected, we can forecast the following future incidents in Russia and the CIS:

1) A criminal group using Cobalt Strike software could continue their attacks in Russia. The gang is expected to steal cash from ATMs in Russia and the CIS;
2) Availability of the Tiny.z banking Trojan for purchase will increase the number of groups using this tool. The Trojan enables hackers to create phishing mobile apps in order to obtain online banking credentials and bank card data. An increase in the number of attacks and banks compromised using this equipment is expected to grow respectively;
3) Another Android Trojan that is expected to be actively developed is Gugi;
4) Jupiter and RTM PC Trojans are expected to evolve and spread actively. Due to a message on search for partners to distribute Jupiter published on an underground forum, the amount of attacks on banks' corporate clients is expected to significantly increase.
5) The ProxyAdder Trojan attacking individuals will reduce its activity because of the problems in their network infrastructure.

Threats to the Financial Sector, Global

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks using the Cobalt Strike software	Russia, Europe	CP-1453 CP-1438-2 CP-1438-3	June 2016

In late June 2016 phishing emails with malicious attachments were detected in a Russian bank. After the malicious attachment was launched, Cobalt Strike remote access tools were installed on the victim's machine. When performing this attack, criminals obtained access to network computers with administrator privileges. Cobalt Strike enabled hackers to analyze installed applications and consoles purportedly in order to get confidential bank data.

Following this, similar attacks were performed in the UK, the Netherlands, Romania, Belorussia, Poland, Spain, Estonia, Bulgaria, Ukraine, China, Thailand. Russian-speaking intruders are believed to be behind these attacks.

Criminals send emails acting as the European Central Bank, the ATM maker Wincor Nixdorf or local banks.

According to investigations of the incidents, the key target of these criminals is to gain total control over ATMs in the bank's network to remotely trigger them to dispense money.

In earlier attacks, the group had targeted SWIFT in China and Ukraine. Information about a successful attack on the system in a Ukrainian bank is widely available. Researchers also detected a software sample adjusted to attack a bank in Hong Kong.

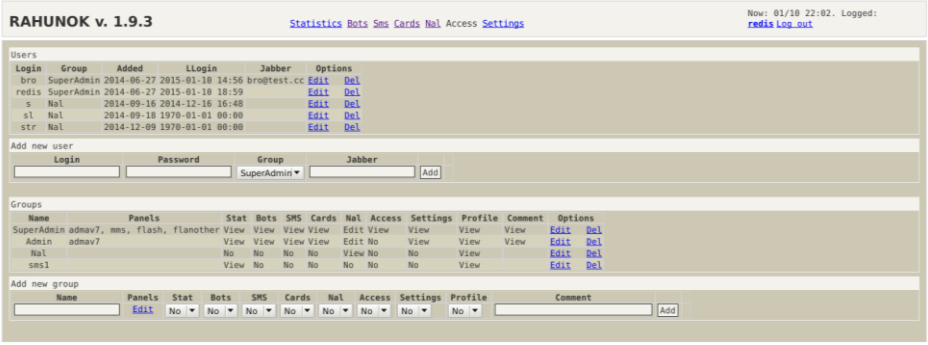
Group-IB's reports contain indicators of compromise for these attacks.

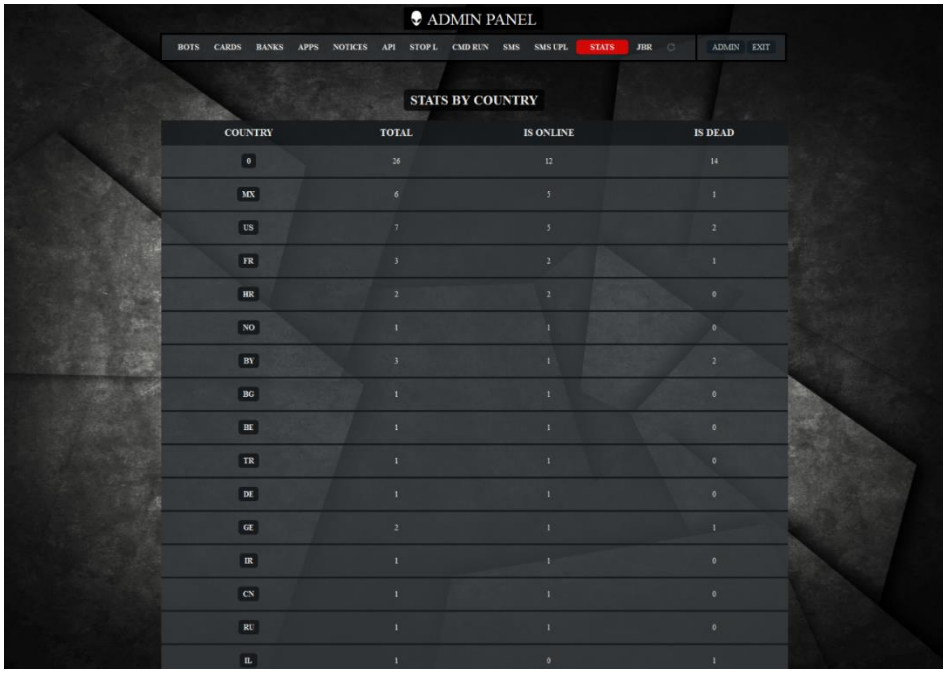
Banking threats for PC and Android

Malware name	Regions attacked	Detection	Notification
Marcher	Australia, Austria, the Czech Republic, Poland, France, the Netherlands, Germany, Turkey	2013	CP-1439 CP-1472

Marcher is an Android banking Trojan. During the reporting period, 3 criminal groups using Marcher were detected: Rahunok, Alien, and MMS-service. That said, they use different versions of the Trojan.

Different control panels of these versions are presented below:





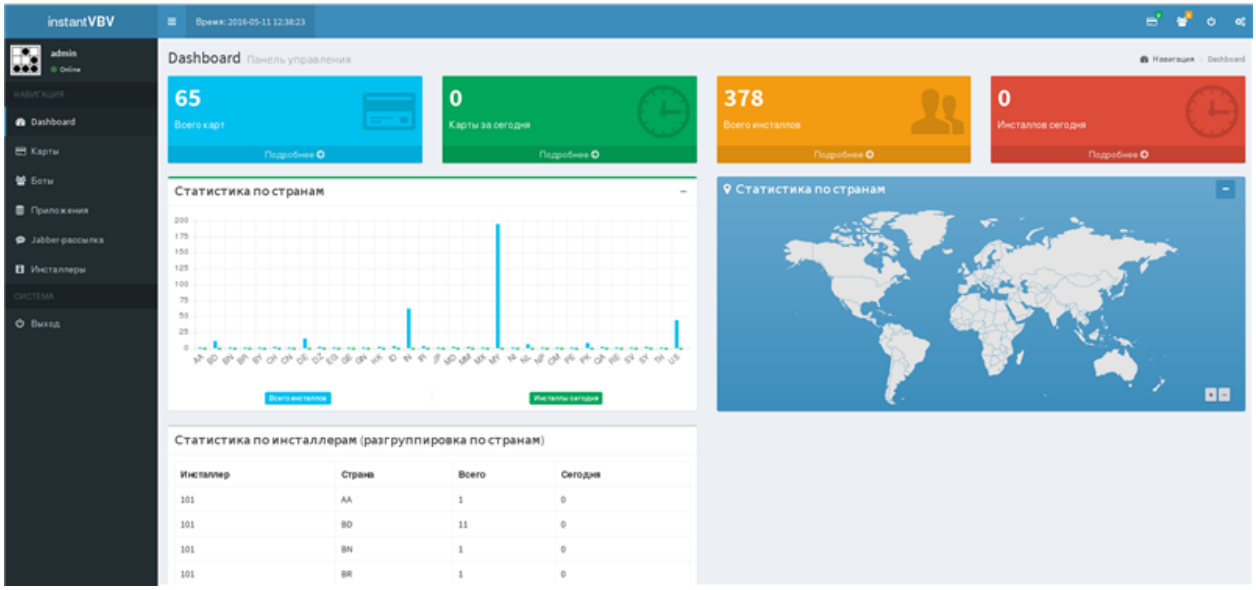
Known targets:

mbank
ingbank
pekao
comarch
bzwbk24
raiffeisen
eurobank
cbplpat
commbank
westpac
stgeorge bank
nab
bankwest
banksa
reditagricole
caisseepargne
labanquepostale
societegenerale
bnpparibas

arkea
fr.lcl
fr.axa.monaxa
banquepopulaire
commerzbank
fiducia
santander
starfinanz
consorsbank
bankaustria
easybank
bawag
volksbank
spardat
deutschebank
lloyds
halifax
tsb
akbank
finansbank
garanti
halkbank
vakifbank
ziraat
paypal
Citibank
CreditAgricole
sparkasse
dzbank

Malware name	**Regions attacked**	**Detection**	**Notification**
Instant VBV Grabber	Europe	July 2016	CP-1437

In July 2016 Group-IB specialists detected attacks on bank clients performed by a criminal group using a malicious program for Android dubbed Instant VBV Grabber. This malware is distributed via SMS spamming acting as the Swiss Post, a national postal service of Switzerland, and Post Danmark A/S, a national postal service of Denmark. The Trojan compromises authentication credentials of online banking users and intercepts SMS messages. An administrative panel that was detected by researchers contained information about 300 infected devices. Infected devices are primarily located in Denmark, China, the USA and Russia. On July 27 2016, Group-IB specialists discovered a new active control panel of Instant VBV Grabber. According to analysis, it contains 255 infected devices and primarily targets clients of banks in Denmark.



Screenshot – Administrative panel of Instant VBV Grabber

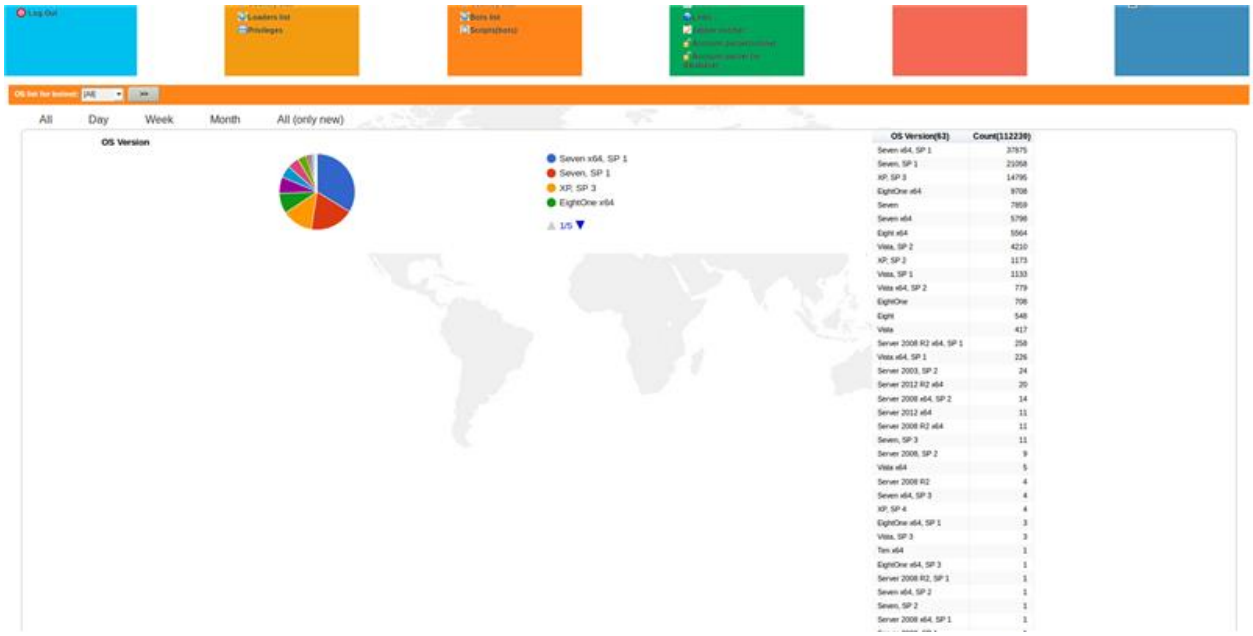
According to analysis of the administrative panel, the following banks suffered attacks using Instant VBV Grabber:

PBS INTERNATIONAL A/S
Crédit Mutuel Arkéa
Barclays Bank PLC
Royal Bank of Scotland
Nordea Bank Danmark A/S
Danske Bank
Teller A/S

It's worth reiterating that this software is sold on underground forms by a user with the nickname GM_Project, who had bought GM Bot source codes from its author GanjaMan.

Malware name	Regions attacked	Detection	Notification
Lider_soft/plan2016	All countries except the CIS	July 2016	CP-1436

This malware is available for lease. It operates on Windows versions from XP to 8.1 (x32/x64). In order to compromise data on infected devices, the malware uses web injection, form grabbers and keylogger modules. It also has Backconnect and VNC functions, can disable Windows Defender and Windows SmartScreen as well as bypass Trusteer Rapport.



Screenshot – Administrative panel

Threat name	Detection	Notification
TrickBot	September 2016	CP-1471

A new malicious program dubbed Trickbot was detected in September 2016. The malware has a configuration file in XML format and uses fake SSL certificates, which is similar to the notorious Dyre banking Trojan. In late 2015 organizers and several members of the Dyre hacker group were arrested. After the arrest, the malicious activity of known botnets and control panels related to their attacks stopped. Trickbot was purportedly developed by those Dyre team members who managed to avoid arrest by authorities.

All detected TrickBot samples are related to a botnet with the testX ID, where X is a number. Group-IB specialists detected 2 modules: a module to collect information on the infected system and a module to monitor launched processes. These facts indicate that this program is currently being tested by cybercriminals.

Both modules collect data in XML format with the same nodes as those that had been used by Dyre. Each module sends collected information to a separate address.

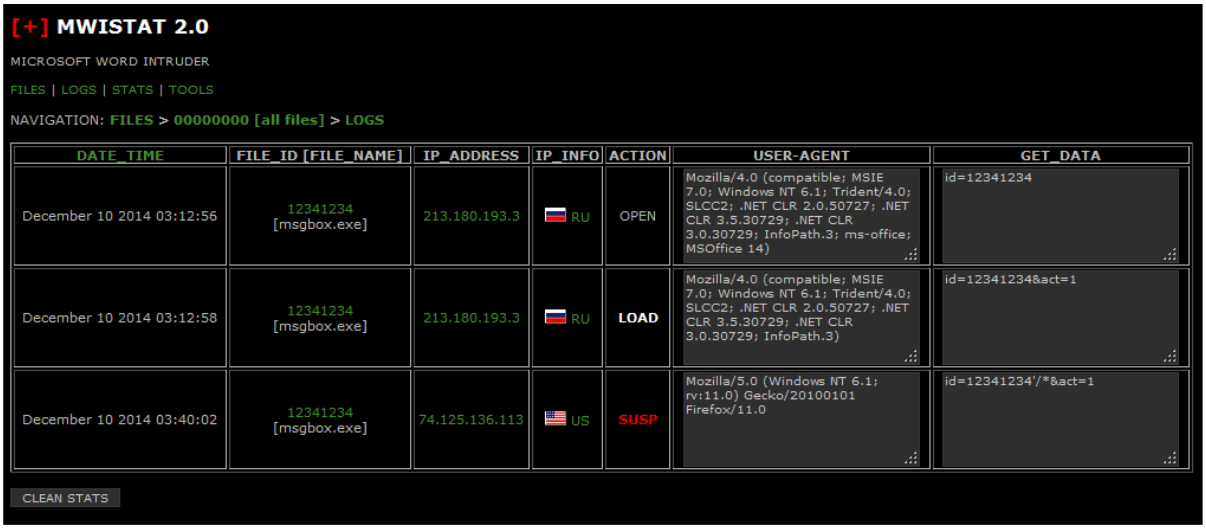
The first module captures all the information on the infected machine, such as a list of programs information on the hardware components (processor, motherboard, computer memory), language, time zone, OS version, list of services, etc.

The second module collects data on the launched OS processes (startup time, execution file, etc.).

At the time of this report, Group-IB specialists have not detected other modules.

Threat name	Detection	Notification
A new exploit in the MICROSOFT WORD INTRUDER exploit kit	August 2016	CP-1446

An announcement about an updated version of the MWI (MICROSOFT WORD INTRUDER) exploit kit was published on an underground forum. Its authors added an exploit for the CVE-2016-4117 vulnerability, the remote code execution flaw. The exploit leverages a check error range in the DeleteRangeTimelineOperation module. A remote attacker can use a customized .swf file to provoke a buffer overflow and execute arbitrary code on the target system. This malware exploits a new vulnerability detected in 2016, which increases the chances of its successful exploitation on the victim's machine.



Screenshot – the MWI control panel

Threat name	Detection	Regions attacked
Fox v1.0 Stealer	August 2016	All countries except the CIS

The author of the Crombot Trojan released a password stealer with a claimed functionality allegedly identical to the infamous Pony stealer and additional functions, which are not specified. The users who tested the malware say that the product is not ready.

Malware name	Regions attacked	Detection
GM Bot (other names: Mazar, SlemBunk, Bankosy, Acecard, Slempo)	Australia	October 2014

In Q3 2016, Group-IB specialists detected a GMBot sample attacking the following banks in Australia:

Bankwest
Mebank
Suncorp

ANZ
Bendigobank
Bank of Melbourne
Banksa
Stgeorge
NAB
Westpac
Commbank

Threat name	**Detection**	**Regions attacked**
Dridex	2014	Europe, Australia

In August 2016, specialists detected new botnets targeting banks in Switzerland, the UK, France, Spain. The malware spread via spam emails with a password-encrypted attachment, which protects it from being detected by the majority of AV systems.

Specilists identified attacks on the following banks: Santander, HSBC, Fbnbank, Barclays, Societe Generale, Bancopopular, Humebank.

Also, in Q3 researchers observed activity of the following banking Trojans:

Name	Detection	Attacked countries	Attacked banks
Qadars	2013	Australia Canada	Commbank Suncorp StGeorge Banksa Bankwest Boq NAB Bankofmelbourne bendigobank bnc.ca wherewebank.com desjardins.com tangerine.ca scotiabank.com rbcroyalbank.com
Gootkit	2014	Great Britain Germany Canada France	hsbc.co.uk santander.co.uk targobank.de norisbank.de berliner-bank.de deutsche-bank.de sparda.de comdirect.de flessabank.de

			gecapital.de commerzbank.de scotiabank.com royalbank.com BMO dkb.de tescobank.com barclays.co.uk bnpparibas lcl.fr
Qbot	2009	USA	Jpmorgan Citibank 53.com Usbank.com Citizensbank Capitalone Suntrust Frostbank Tdbank
Tinba	2012	UK Italy USA Spain Germany Australia Canada	Lloydsbank chebanca.it bankofamerica halifax.es wellsfargo fiducia.de deutsche-bank.de postbank.de ANZ Banksa Bankofmelbourne Stgeorge NAB westpac cibc BMO royalbank.com Desjardins Chasecanada Capitalone USAA
Zeus	2007	USA Spain Germany Belgium UK Italy UAE	Wellsfargo Paypal Usbank Citizensbank Suntrust 53.com Chase banesto.es gruposantander.es bancopopular

			Caixa BBVA Norisbank citibank.de procreditbank.bg barclays.com Lloyds HSBC Dab-bank Halifax poste.it bancaintesa.it iwbank.it citibank.ae santander
ZeusVM (KINS)	2013	UK USA Australia	tescobank.com lloydsbank.co.uk hsbc.co.uk halifax-online.co.uk citi Barclays Bankofscotland Santander HSBC usaa.com mtb.com wellsfargo usbank.com suntrust.com pnc.com firstbankcard.com chase bankofamerica bbt.com capitalone adelaidebank.com.au anz.com bankwest bendigobank boq commbank suncorp stgeorge peopleschoicecu banksyd ING Banksa Vancity Desjardins cibc.com

			scotiabank.com BMO ptsbank.co
Vawtrak	2013	USA Germany UK Canada	bankofamerica.com tdbank.com americanexpress capitalone chase citi deutsche bank discoverbank etrade.com fidelity hmrc lloydsbank.de btbanking.com pnc.com bbt.com usaa.com wellsfargo westlaw.de Santander Jpmorgan Ulsterbank rbc.com
ISFB (Gozi)	2013	Italy Germany France Switzerland Netherlands Poland Hungary Czech Republic	Group-IB specialists analyzed the following samples used to attack Italy: csebanking.it poste.it bpmbanking.it cartasi.it bancaincasa.sba.bcc.it bancacrfirenze.it bancopopolare.it btbonline.it businesswaybnl.it
Atmos		Portugal Spain Netherlands UK France Canada	montepio.pt finibanco.pt activobank.pt bancopopular.pt barclays.pt deutsche-bank.pt bancobest.pt bpinetempresas.pt cajamadridempresas.es cajaespana.net lloydsbankinternational.es bbvanetcash.com mijn.ing.nl

			santander.co.uk nationwide.co.uk barclays.co.uk nationwide.co.uk labanquepostale.fr banquepopulaire.fr creditmutuel.fr lcl.fr bmo.com chasecanada.ca cibc.com desjardins.com mbna.ca rbcroyalbank.com tangerine.ca td.com
Kronos		USA	Bank of America Wellsfargo

Attacks on ATM and POS terminals

1) ATMs both in Russia and worldwide are targeted by a new APT using Cobalt Strike software. This attack is aimed at infecting ATM control systems. When accessing them, perpetrators send a command to make the cash machine dispense money. Detailed information is available in Notifications CP-1438, CP-1438-2, CP-1438-3.
2) In July specialists detected announcements of a skimming device named EMV skimmer available for purchase. This skimmer is able to steal information from chip-equipped cards instead of cloning their magnetic stripe predecessors. According to the seller, it's powered by an equipment for the point of sale terminal and a program to process card data received.

   In August at the BlackHat 2016 convention security researchers delivered a report on EMV skimmers. Through their investigation specialists analyzed methods of obtaining data and bypassing chip the card protection system (iCVV – integrated circuit card verification value).

   According to the study, criminals can successfully use EMV skimmers in one of the following ways:
   - Hackers can use EMV skimmer to steal Track1 + Track2 card dumps for POS systems and a PIN code.
   - A card dump (Track1+Track2) contains information about the bank card, such as a card number, credit card holder name, expiration date. This information can be employed in fraudulent transactions, for example, for purchases in online stores.
   - Criminals can record Track2 on a magnetic stripe of a blank plastic card and use such a card to pay via POS terminals operating in offline mode.
   - Criminals can record Track2 on a magnetic strip of a blank plastic card and use such a card to pay via POS terminals, where the so-called “technical fallback” is permitted. This technology means that the magnetic stripe can be used instead of the chip.

   Detailed information on this threat is available in Notification CP-1450.

Phishing attacks

1) In July 2016 specialists detected a phishing attack against an online travel company, Expedia. Criminals intercepted victims' authentication data to get into portal's personal accounts and access all the sensitive information (booking data, bank card data, payment amounts, clients' personal information). Victims included Expedia partners and clients. Also, cybercriminals have scripts designed to grab bank card data from personal accounts. Detailed information on this threat is available in Notification CP-1440.
2) In September 2016, Group-IB researchers detected a vishing fraudulent scheme aimed at capturing bank card data. Criminals sent fake SMS messages containing texts adjusted for clients of specific banks in order to make victims call a specific number. When the victim calls the number, they are answered by automated instructions to enter his or her credit card number on the key pad. Criminals have been using this scheme since at least 2014. Group-IB specialists are continuing investigation on this campaign. According to analysis, banks of the USA and Canada are currently under threat. All information on this threat is available in Notification CP-1459.

DDoS attacks

Threat name	Detection	Related notification
Mirai DDoS bot	September 2016	CP-1473

Hackers released the source code for the Mirai malware designed to hijack connected Internet of Things (IoT) devices turning them into botnets. Purportedly, such a botnet was behind the world's largest ever DDoS attacks against the website of security journalist Brian Krebs' and the OVH hosting provider. The attacks peaked at more than one terabit or 1,000 gigabits per second. The botnet has infected over 150,000 infected IoT devices, which are primarily CCTV cameras and digital video recorders.

Data leakage

During the reporting period, the following major data breaches were detected:

- On 10.07.2016 roughly 324,000 financial records from the payment processor BlueSnap were published online. According to analysis of the database performed by Group-IB specialists, it contains data about transactions from Russian and foreign banks. The first payment is dated march 10, 2014; the last one is dated May 20, 2016. The database contains information on the cardholder – Name, Surname, Address, Phone number, email address, as well as bank card data -– the last four digits, expiration date, CVV codes.
- Email and password data for more than 68 million Dropbox users is for sale in the darknet marketplace. The data was stolen in 2012.
- In early September the forum and popular porn site Brazzers was hacked. As a result, 790,724 users' information including email addresses and login credentials leaked online.
- Breached in 2012, hackers have now leaked data of nearly 100 million users of Rambler.ru by placing on the A the Real Deal underground forum.

Threats to the Financial Sector in Russia

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attack on a bank using the Cobalt Strike program	Russia, Europe	CP-1438 CP-1438-2 CP-1438-3	June 2016

In late June 2016 phishing emails with malicious attachments were detected in a Russian bank. After the malicious attachment was launched, Cobalt Strike remote access tool was installed on the victim's machine. When performing this attack, criminals obtained access to network computers with administrator privileges. Cobalt Strike enabled hackers to analyze installed applications and consoles purportedly in order to get confidential bank data.

Following this, similar attacks were performed in the UK, the Netherlands, Romania, Belorussia, Poland, Spain, Estonia, Bulgaria, Ukraine, China, Thailand. Russian-speaking intruders are believed to be behind these attacks.

Criminals send emails acting as the European Central Bank, the ATM maker Wincor Nixdorf or local banks.

According to investigations of the incidents, the key target of these criminals is to gain total control over ATMs in the bank's network to further remotely trigger them to dispense money.

In earlier attacks, the group had targeted SWIFT in China and Ukraine. Information about a successful attack on the financial processing system in a Ukrainian bank is widely available. Researchers also detected a software sample adjusted to attack a bank in Hong Kong.

Group-IB's reports contain indicators of compromise for these attacks.

APT name	Regions attacked	Related notifications	Operation start
Targeted attack using the Ostin malware	Russia	CP-1457	August 2016

Specialists detected a targeted attack when hackers compromised accounts in corporate networks and infected systems with Ostin malware. This new program has the functionality for espionage and remote control over infected machines. It is also capable of downloading and executing additional files. During the attack, perpetrators also used a set of utilities to perform all sorts of adminstrative tasks on remote Microsoft Windows-based computers – PsTools.

Banking Trojans for PC and Android

Threat name	Detection	Regions attacked
Gugi/Limebot	August 2016	Russia

A new version of the Gugi banking Trojan for Android appeared. The malware is now able to bypass security systems on the Android OS, version 6.0. The Trojan spreads via SMS spamming and uses fake windows to capture data. The malware is known to focus on Russian banks with the following key targets:

- SberBank
- *Tinkoff Bank*
- *VTB24*
- *Alfa Bank*
- Raiffeisen Bank Russia

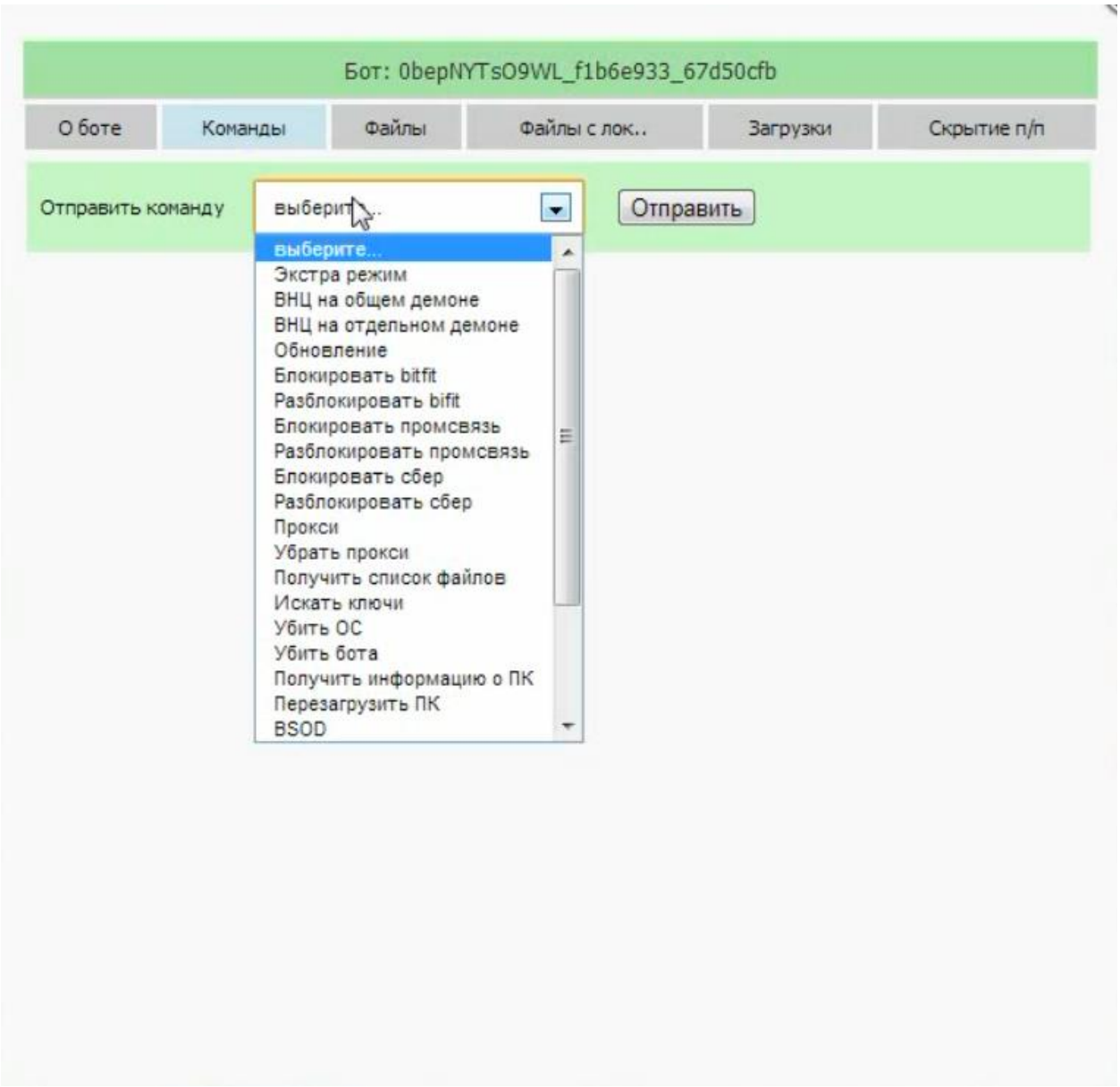
Malware name	**Regions attacked**	**Related notifications**	**Detection**
Ranbyus	Russia	CG-1435 CG-1435-2	2012

In July 2016 Group-IB specialists detected spam emails with a malicious attachment – the Ranbyus banking Trojan. The malware targets online banking and payment systems.

It's worth reiterating that the Trojan scans for addresses containing the following substrings: «bsi.dll?», «online.payment.ru», «/sbi.sberbank», «bankline.ru/servlets/ibc», «faktura.ru», «/iclient/», «ibank2», «bco.vtb24.ru». The malware also searches for the following processes launched in the system: PuTTY SSH client, Webmoney, Payment systems CONTACT, WESTERN UNION, iFOBS, BSS Local client, Tiny Client bank, UNISTREAM, Client bank (InterPro), Nomos Regiobank, BankKlient. In addition, the Trojan targets Avangard Internet Bank, IFobs, LIFE Financial Group Internet Bank, ROSBANK Internet Client-Bank Server, «BS-Client», R-Connect online banking, Alfa-Client On-line.

In August, researchers detected a Ranbyus sample, whose configuration file contains a code to perform automatic manipulations in the 1C:Enterprise system. The malicious activity starts when the user performs a transaction from the system to the recipients, whose names include one of the following words: «УФК» (Federal treasury department) /«ИФНС» (Federal Tax Service Inspectorate) /«казначейства» (treasuries) /«Федерального» (Federal). During this attack recipient's payment data is substituted.

This malware is believed to be dangerous to all companies using the 1C:Enterprise system.



Screenshot – Command menu in the Ranbyus administrative panel

Malware name	Regions attacked	Detection	Notification
RTM	Russia	December 2015	CP-1359-2

This malware is a modular Trojan written in Delphi. It has the functionality to attack online banking and payment systems.

The last detected Trojan sample scans the infected machine for the following online banking systems:

online.payment.ru
bankline.ru
/ic/login.zhtml
/servlets/ibc
faktura.ru
bco.vtb24.ru
elbrus.raiffeisen
elba.raiffeisen
handybank
wupos.westernunion
online.sberbank
SberBank_PC
Raiffeisen
SberBank_Fiz
QiwiCashier

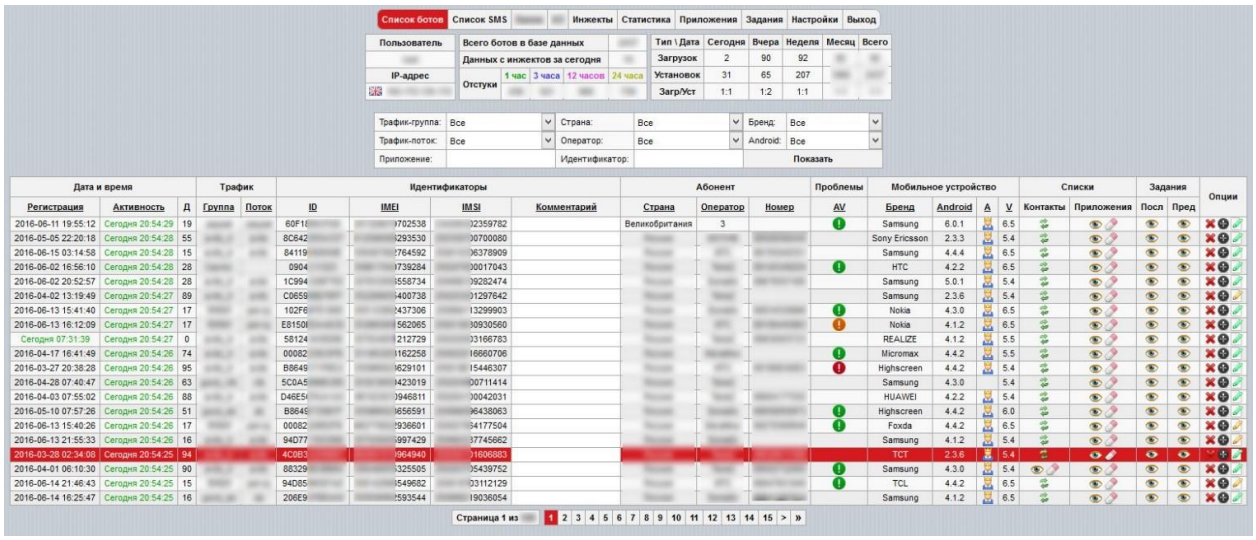
Criminals are believed to distribute the Trojan using the following exploit kits sold on underground platforms: Beps Exploit Kit, RIG Exploit Kit. Hackers also use the Godzilla Loader malicious program.

Malware name	Regions attacked	Detection	Notification
Tiny.z	All countries	Early 2016	CP-1447

In early 2016 a new Android Trojan dubbed Tyny.z was detected. In Q1 2016 it was used only by the 404 criminal group. They attacked the following Russian and foreign banks using a botnet named MarsElite Android BotNet:

Sberbank
Raiffeisen Bank
Russian Standard Bank,
VTB 24
Alfa-Bank
PrivatBank
QIWI
Commonwealth bank
NAB bank
St. George bank

However, in August criminals started selling the Trojan under the name “Catelites Android Bot” on the deep web. Criminals purportedly decided to lease their malware because of the group member’s arrest. This will help them confuse investigators, because other groups will also use the malware.



Screenshot – the Catelites Android Bot administrative panel

Attacks on ATMs

ATMs both in Russia and worldwide are targeted by a new APT using Cobalt Strike software. This attack is aimed at infecting ATM control systems. When accessing them, perpetrators send a command to make the cash machine dispense money. All detailed information is available in Notifications CP-1438, CP-1438-2, CP-1438-3.

Data leakage

During the reporting period Group-IB specialists detected 11 incidents of providing/selling/ searching for confidential bank data related to Russian banks on underground resources.

They include:

- Sales of clients’ databases;
- Sales of login credentials to enter an automatic banking system;
- Search for insiders in banks to commit fraud.

On 10.07.2016 roughly 324,000 financial records from the payment processor BlueSnap were published online. According to analysis of the database performed by Group-IB specialists, it contains data about transactions from Russian and foreign banks. The first payment is dated march 10, 2014; the last one is dated May 20, 2016. The database contains information on the cardholder – Name, Surname, Address, Phone number, email address, as well as bank card data - – the last four digits, expiration date, CVV codes.

Threats to the Government sector

APT

APT name	Regions attacked	Operation start
Fancy Bears (other names Sofacy, APT28, Sednit, Pawn Storm, Strontium, Tsar Team)	Canada, USA, Ukraine, France, Greece, UK, Jordan, Belgium	2008

Fancy Bear hacker group accessed confidential documents of the World Anti-Doping Agency (WADA), which were partly published on their website. This attack followed a ban on Russian athletes at the Rio Olympics because of the doping scandal.

It's worth reiterating that this hacker group has been active since 2008. They perform cyber espionage and data thefts by attacking government agencies, military departments, and military-industrial companies.

APT name	Regions attacked	Operation start
Buckeye (APT3, GothicPanda, UPSTeam, TG0110)	Hong Kong, USA, UK	2000

Traditionally, the group attacked organizations in the US. However, Buckeye's focus appears to have changed in 2015. The group began compromising political organizations in Hong Kong. Since March 2016, they have appeared to mostly focus on organizations in Hong Kong, sending malicious emails to targets and attempting to spread within compromised networks in order to steal information.

The majority of the groups' hacking tools are open source applications. Buckeye primarily uses tools: a remote access Trojan named Backdoor.Pirpi, keylogger, RemoteCMD, PwDumpVariant, OSinfo, ChromePass, Lazagne.

Buckeye seems to target file and print servers, which makes it likely the group is looking to steal documents. This fact together with the group's use of zero-day exploits in the past, would suggest that Buckeye is a state-sponsored cyberespionage group.

APT name	Regions attacked	Operation start
Patchwork	USA, Europe, the Asia-Pacific region	2014

In July 2016 security experts spotted a new cyber espionage campaign managed by the Patchwork APT group targeting organizations in multiple industries. First attacks of this gang were detected in December 2015. The main feature of this group, which is purportedly based in India, is that the Patchwork activities leverage on ready-made malicious codes from open source projects and underground forums. The group uses spear phishing emails with an infected attachment. The PowerPoint files appear to exploit the Microsoft Windows OLE Package Manager Remote Code Execution Vulnerability (CVE-2014-

4114). This attack targeted specific employees of a government-associated organization in Europe. Once criminals obtained sustainable access to the victim's computer, they downloaded the malware.

APT name	Regions attacked	Operation start
ProjectSauron	Russia, Iran, Ruanda	June 2011

ProjectSauron is a modular cyber-espionage platform designed to perform long-term campaigns. Usually it registers its persistence module on domain controllers as a Windows LSA (Local Security Authority) password filter. That's how the ProjectSauron passive backdoor module starts every time any network or local user (including an administrator) logs in or changes a password, and promptly harvests the password in plaintext.

These attacks target the following types of organizations: Government, Scientific research centers, Military, Telecommunication providers, Finance.

Hacktivism

In Q3 2016, hacktivists conducted over 2400 attacks on more than 3300 various online resources. Over 2500 attacks detected were of "page replacement" type (Deface) and 937 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks including those of Israel, the USA, Turkey, Russia, Peru, the UK, India, Germany, Brazil and Venezuela. The most active gangs which are believed to have concentrated their attacks on one country were AnonymousCenter (attacks on Brazilian websites); AleviHackers (attacks on Turkish resources); Anonymous Nigeria (attacks on websites of Nigeria); AnonIron, Leonidus2015 (attacks on the US resources); Anonymous Red Cult (attacks on Israeli websites).

The table below contains information on the major hacktivists' operations conducted in Q3 2016.

Operation name	Regions attacked	Operation start	Types of attacks during the operation
OpISIS	ISIS, Middle East, Islamic organizations all over the world	11.08.2014	DDoS
	During the OpISIS operation hackers attacked websites related to terrorism as well as religious and information Islamic websites and media resources. In Q3 2016 166 attacks were detected in total with a major part of them organized by BinarySec and VacuumCyborg hacker groups.		
OpIsrael	Israel	7.04.2013	DDoS, Deface
	OpIsrael is an annual operation against Israeli websites and online resources. During the operation hacktivist groups attack government, educational, banking and non-governmental resources and media portals. The operation starts on April 7th every year.		

OpBEAST, OpWhales, OpKillingBay	North America, Northern Europe, Southeast Asia		DDoS
	OpBEAST, OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Initially they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. Currently, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants, and Texas government organizations (USA).		
OpIcarus	North America, Northern Europe, East and Southern Africa, North Africa, Southwest Asia	03.05.2016	DDoS
	During the operation hackers attacked banking and financial institutions of various countries, such as Lloyds Bank, Colombo Stock Exchange, Bermuda Monetary Authority.		
OpGabon	The Gabonese Republic	1.04.2013	DDoS
	*T*he operation targets online resources of Gabon. It was initiated by the Anonymous group protesting against controversial results of the Gabon's presidential election.		
OpVenezuela	South America	20.01.2011	DDoS, Deface
	During this campaign, government resources in Latin America were attacked. This operation was initiated by the Anonymous group following violent repression against anti-government protesters and instances of internet censorship. In Q3 2016 38 attacks were detected during the operation, which were primarily performed by the Polish Cyber Army hacktivist group.		
OpTurkey	Turkey	10.09.2014	DDoS, Deface
	This operation was initiated by the Anonymous group. This campaign was provoked by the deaths of 10 construction employees. The workers were killed when their elevator crashed. Anonymous expressed their outrage at what they saw as Turkey's lack of both funds & safety measures regarding construction sites and workplaces.		
OpChina	China, Palau	30.05.2013	DDoS, Deface
	The campaign was initiated by the Anonymous hackers. The claimed reason is Internet censorship in China.		
OpBlackFlare	USA	1.07.2016	DDoS
	This operation was initiated by the Anonymous group. The campaign is designed to fight back against several forms of police misconduct: false arrest; intimidation; racial profiling; political repression, etc.		
OpClosedMedia	Europe	22.09.2016	DDoS
	The campaign was initiated by the PowerfuLGreEkArmy group. According to their statements, the group embarked on a campaign to take down news media organizations for the generic reasons of “not reporting on the real news” and being “government controlled.”		
OpSerenaShim	Turkey, Saudi Arabia, NATO servers	12.12.2014	DDoS

	The campaign is related to Serena Shim, an American journalist, who was allegedly killed in a car crash two days after Turkey accused her of spying. Shim covered reports for Press TV in Lebanon, Iraq, Ukraine and Turkey.

Data leakage

During the reporting period the following political data leaks that were widely covered by media:

- Fancy Bears hacker group (also known as Sofacy, APT28, Sednit, Pawn Storm, Strontium, Tsar Team) accessed confidential documents of the World Anti-Doping Agency (WADA), which were partly published on their website. This attack followed a ban on Russian athletes at the Rio Olympics because of the doping scandal.
- The US election campaign is continuously under threat of cyber-attacks. Hackers attacked Trump's campaign computer systems.
- Hackers published a data array containing email messages of Andrey Purgin, a Ukrainian activist, co-founder of the self-proclaimed Donetsk People's Republic (DPR). The archive contains DPR's internal documentation, bank payment orders, administrative notes, etc.

A large leak occurred in the hacking world: a group named Shadow Brokers breached databases of Equation Group, which had developed Stuxnet, Duqu, Flame, Duqu2 malware to perform attacks on governments and enterprises. The rest of the data is being auctioned. The leak is a potential threat to governments, large enterprises, and financial institutions. Detailed information is available in Notification DL-1461.